

O relatório de 2020, "The Cost of Poor Quality Software in US.", aborda o alto custo gerado pela falta de atenção primária e consistente à qualidade de software. Esse problema foi evidenciado entre 2019 e 2020, um período marcado por grandes falhas, como ataques de ransomware, vazamento de dados e quedas de sistemas, que causaram bilhões em prejuízos e destacaram o cibercrime como área de maior crescimento.

A origem desses prejuízos está em um conjunto de fatores interligados. O desafio da digitalização é equilibrar velocidade, qualidade e segurança, mas o relatório aponta que esse equilíbrio não está sendo alcançado de forma eficaz. A falha nesse processo resulta em custos crescentes, com a cibersegurança impactando os custos atuais e a dívida técnica (código com má qualidade) gerando custos futuros.

* **Projetos mal-sucedidos:** Segundo o relatório CHAOS 2020, 19% dos projetos de TI são cancelados e apenas 35% são considerados bem-sucedidos. Esses fracassos custaram US\$ 260 milhões bilhões nos EUA em 2020, e são atribuídos a fatores não técnicos, como a ausência de um bom patrocinador, uma boa equipe e um bom ambiente.

* **Sistemas legados:** A má qualidade em sistemas legados representou um custo de US\$ 520 bilhões em 2020. A manutenção desses

Sistemas é difícil e eles frequentemente se tornam ineficientes e inseguros.

* Fator Humano: O relatório de 2019 indica que 34% dos ataques cibernéticos foram causados por ações, intencionais ou não, de funcionários internos.

O problema é ampliado pela falta de profissionais qualificados. O artigo apontava que apenas 2% da população mundial sabia programar, enquanto a demanda por esses profissionais estava prevista para 24% nos sete anos seguintes, sem que a educação conseguisse acompanhar o ritmo.

A causa fundamental de muitos problemas são as falhas estruturais em software. O texto diferencia os conceitos de fraqueza (um erro no código que pode se tornar um problema) e vulnerabilidade (uma fraqueza que pode ser diretamente explorada por um hacker). Cada linguagem de programação tem seus próprios riscos:

→ C e C++ são suscetíveis a ataques de buffer overflow.

→ SQL e PHP são vulneráveis a injeção de código.

O uso de código aberto e bibliotecas de terceiros também contribui para esse cenário, pois muitos desses componentes contêm vulnerabilidades já catalogadas.

Para mitigar esses desafios, o selecionador sugere uma mudança na abordagem de desenvolvimento. Em vez de deixar a qualidade e os testes para o final do processo, a solução é o conceito de "shift-left quality", que prioriza a detecção de defeitos no início.

As recomendações incluem:

→ Priorizar a prevenção de falhas o mais cedo possível, pois as correções na fase inicial custam 10 vezes menos do que as falhas operacionais.

→ Analisar o código-fonte regularmente antes do lançamento para encontrar vulnerabilidades, especialmente as mais custosas e difíceis de corrigir.

→ Tratar a melhoria da qualidade como um processo iterativo, contínuo e incremental.